

附件 1 資通系統防護基準檢核表

資通系統防護基準檢核表(普級系統適用)

資通系統名稱	
機關單位名稱	
填寫人員	
填寫日期	
審核人員	

構面	類別	項次編號 (原始)	最低系 統等級 要求	控制措施	是否符合	現況說明	佐證	矯正作為	目標日期	備註說明
存取控制	帳號管理	1	普	建立帳號管理機制，包含帳號之申請、建立、修改、啟用、停用及刪除之程序。	符合	依「ISMS_WI_016 網站管理辦法」之規範，網站管理帳號變更/新增之申請，需填寫「流程服務管理系統」之「系統帳號/權限異動申請表」，由網站管理者進行變更/新增作業。	1.系統帳號/權限異動申請表 2.帳號權限審核紀錄			
		2	普	已逾期之臨時或緊急帳號應刪除或禁用。	符合	1.臨時帳號建立時由系統設定帳號使用截止日期，逾期自動禁用。 2.每季進行系統帳號權限審查。	1.系統功能規格書/測試記錄 2.帳號權限審核紀錄			
		3	普	資通系統閒置帳號應禁用。	符合	1.系統實作每日檢查排程，自動禁用逾 180 天未登入之帳號。 2.每季進行系統帳號權限審查。	1.系統功能規格書/測試記錄 2.帳號權限審核紀錄			
		4	普	定期審核資通系統帳號之申請、建立、修改、啟用、停用及刪除。	符合	每季進行帳號權限審查。	帳號權限審核紀錄			
	最小權限	9	普	採最小權限原則，僅允許使用者（或代表使用者行為之程序）依機關任務及業務功能，完成指派任務所需之授權存取。	符合	由網站管理者依「流程服務管理系統」之「系統帳號/權限異動申請表」內容進行作業，設定申請核可之權限。	系統帳號/權限異動申請表			
	遠端存取	10	普	對於每一種允許之遠端存取類型，均應先取得授權，建立使用限制、組態需求、連線需求及文件化。	符合	本系統僅限以內部網路特定 IP 白名單連線至系統管理後臺，並禁止使用 VPN 連線。	1.系統管理維護手冊 2.系統本機防火牆設定			
		11	普	使用者之權限檢查作業應於伺服器端完成。	符合	於伺服器端實作 RBAC 集中授權機制。	系統功能規格書			
		12	普	應監控遠端存取機關內部網段或資通系統後臺之連線。	符合	戰情室監控人員依「ISMS_PRC_010 系統監	系統監看程序			

構面	類別	項次編號 (原始)	最低系 統等級 要求	控制措施	是否符合	現況說明	佐證	矯正作為	目標日期	備註說明
						看程序」進行系統異常事件通報。				
		13	普	應採用加密機制。	符合	已全站台啟用 HTTPS。	系統連線畫面			
		14	普	遠端存取之來源應為機關已預先定義及管理之存取控制點。	符合	本系統僅限以內部網路特定 IP 白名單連線至系統管理後臺，並禁止使用 VPN 連線。	1. 系統管理維護手冊 2. 系統本機防火牆設定			
事件日誌與可歸責性	記錄事件	15	普	訂定日誌之記錄時間週期及留存政策，並保留日誌至少六個月。	符合	資通系統日誌檔案留存於資料庫及日誌伺服器，依中心資安規範至少會保留 6 個月，惟系統未限制日誌留存期限，除非由管理者手動刪除否則會長期留存。	資通系統日誌			
		16	普	確保資通系統有記錄特定事件之功能，並決定應記錄之特定資通系統事件。	符合	資通系統日誌紀錄包含帳號登入成功、登入失敗、帳戶鎖定、系統異常以及管理者執行動作等特定事件。	1. 系統功能規格書 2. 資通系統日誌			
		17	普	應記錄資通系統管理者帳號所執行之各項功能。	符合	資通系統日誌紀錄包含管理者執行動作。	1. 系統功能規格書 2. 資通系統日誌			
	日誌紀錄內容	19	普	資通系統產生之日誌應包含事件類型、發生時間、發生位置及任何與事件相關之使用者身分識別等資訊，採用單一日誌機制，確保輸出格式之一致性，並應依資通安全政策及法規要求納入其他相關資訊。	符合	1. 資通系統日誌以人事時地物描述特定事件。 2. 統一使用 NLog 日誌記錄框架確保格式一致性。 3. 已於日誌內留存所有必要資訊。	1. 系統功能規格書 2. 資通系統日誌			
	日誌儲存容量	20	普	依據日誌儲存需求，配置所需之儲存容量。	符合	日誌檔案儲存於資料庫，資料庫已設定容量警示以進行擴充。	資料庫容量警示規則			
	日誌處理失效之回應	21	普	資通系統於日誌處理失效時，應採取適當之行動。	符合	系統已實作例外處理機制，當日誌處理失效時自動寄發警示 Email。	Email 警示信件			

構面	類別	項次編號 (原始)	最低系 統等級 要求	控制措施	是否符合	現況說明	佐證	矯正作為	目標日期	備註說明
	時戳及校時	23	普	資通系統應使用系統內部時鐘產生日誌所需時戳，並可以對應到世界協調時間(UTC)或格林威治標準時間(GMT)。	符合	日誌時戳已使用作業系統時間，並以慣用時間日期格式呈現。	資通系統日誌檔案			
		24	普	系統內部時鐘應定期與基準時間源進行同步。	符合	與中心自建之 NTP Server(IP:10.20.30.40)進行同步。	NTP 同步測試			
	日誌資訊之保護	25	普	對日誌之存取管理，僅限於有權限之使用者。	符合	系統日誌檔案僅限資料庫管理者及日誌伺服器管理者存取。	資料庫登入權限、日誌伺服器登入權限			
營運持續計畫	資料備份	28	普	訂定資料可容忍損失之時間要求。	符合	本系統 RPO 訂定為 4 小時。	1. 系統風險評鑑表 2. 資訊資產清冊			
		29	普	執行資料備份。	符合	系統資料依規定保管存放於中心建構管理區。	建構管理區			
	系統備援	33	普	訂定資通系統從中斷後至重新恢復服務之最大可容忍中斷時間要求。	符合	本系統 RTO 訂定為 4 小時。	1. 系統風險評鑑表 2. 資訊資產清冊			
識別與鑑別	使用者之識別與鑑別	36	普	資通系統應識別及鑑別使用者，並禁止使用者使用共用帳號。	符合	為後臺管理者帳號開立具管理權限之個人帳號，停用 Administrator 帳號，並禁止共用帳號。	系統特權帳號審查紀錄			
	身分驗證管理	38	普	使用預設密碼初次登入系統時，應於登入後立即變更。	符合	密碼皆為自行設定，未使用預設密碼。	系統功能規格書			
		39	普	身分驗證相關資訊不以明文傳輸。	符合	全站台啟用 HTTPS。	系統連線畫面			
		40	普	具備帳戶鎖定機制，帳號登入進行身分驗證失敗達五次後，至少十五分鐘內不允許該帳號繼續嘗試登入或使用機關自建之失敗驗證機制。	符合	本系統以自然人憑證登入，具帳戶鎖定機制。	自然人憑證鎖定			
		41	普	使用密碼進行驗證時，應強制最低密碼複雜度；依機關密碼效期規定變更密碼。	不適用	本系統以自然人憑證登入，站台無法強制密碼複雜度及效期，故不適用。	系統登入頁面			

構面	類別	項次編號 (原始)	最低系 統等級 要求	控制措施	是否符合	現況說明	佐證	矯正作為	目標日期	備註說明
		42	普	密碼變更時，至少不可以與前三次使用過之密碼相同。	不適用	本系統以自然人憑證登入，站台不提供自然人密碼變更功能，故不適用。	系統登入頁面			
		43	普	第四點及第五點所定措施，對外部使用者，機關得自行規範辦理。	符合	本系統內部站台，僅限機關內部使用者存取。	系統登入頁面			
	鑑別資訊 保護	46	普	資通系統應遮蔽鑑別過程中之資訊。	符合	本系統以自然人憑證登入，系統以星號遮蔽密碼字元。	密碼登入頁面截圖			
系統與 服務獲得	系統發展 生命週期 需求階段	48	普	針對系統安全需求(含機密性、可用性、完整性)進行確認。	符合	本系統 RFP 已具體描述系統安全需求，並確認符合資通系統防護基準之規範。	系統 RFP			
	系統發展 生命週期 開發階段	51	普	應針對安全需求實作必要控制措施。	符合	本系統 RFP 已具體描述系統安全需求，並要求開發人員確實實作相關功能	1. 系統 RFP 2. 系統功能規格書			
		52	普	應注意避免軟體常見漏洞及實作必要控制措施。	符合	已要求開發人員注意安全程式撰寫原則，避免 OWASP Top 10 等常見網站弱點，並配合弱點掃描與源碼檢測活動，檢測是否存在安全漏洞。	1. 系統 RFP 2. 系統功能規格書 3. 弱點掃描報告 4. 源碼檢測報告			
		53	普	發生錯誤時，使用者頁面僅顯示簡短錯誤訊息及代碼，不包含詳細的錯誤訊息。	符合	使用客製化頁面，僅顯示錯誤代碼及系統負責人員聯絡方式。	系統錯誤頁面			
	系統發展 生命週期 測試階段	56	普	執行「弱點掃描」安全檢測。	符合	已於系統上線前完成弱點掃描，每季依規定進行弱點掃描，並保存弱掃報告及修補紀錄。	弱點掃描報告、弱點掃描修補紀錄			

構面	類別	項次編號 (原始)	最低系 統等級 要求	控制措施	是否符合	現況說明	佐證	矯正作為	目標日期	備註說明
	系統發展 生命週期 部署與維 運階段	58	普	於部署環境中應針對相關資通安全威脅，進行更新與修補。	符合	1. 進行作業系統之安全性更新前，定期於每月底評估、測試與更新。 2. 每季以 NuGet 套件更新機制更新函式庫版本。	每季系統元件更新紀錄			
		59	普	識別並關閉不必要服務及埠口。	符合	僅開放 80、443 及 3389。	Nmap Port Scan 畫面截圖			
		60	普	資通系統不使用預設密碼。	符合	IIS 伺服器、SQL Server 資料庫等皆未使用預設密碼。	現使用之 IIS 及 SQL Server 版本皆未內建預設密碼			
		61	普	執行系統源碼備份。	符合	系統源碼依規定保管存放於中心建構管理區。	建構管理區			
	系統發展 生命週期 委外階段	63	普	資通系統開發如委外辦理，應將系統發展生命週期各階段依等級將安全需求（含機密性、可用性、完整性）納入委外契約。	不適用	系統為自行開發，未委外辦理。	系統建置計劃書			
	獲得程序	64	普	識別資通系統使用之第三方軟體、服務、函式庫或其他元件。	符合	系統所使用第三方元件已造冊列管。	第三方元件清單			
	系統文件	66	普	應儲存與管理系統發展生命週期之相關文件。	符合	系統文件皆依規定保管存放於中心建構管理區。	建構管理區			
系統與 資訊完 整性	漏洞修復	72	普	系統之漏洞修復應測試有效性及潛在影響，並定期更新。	符合	1. 進行作業系統之安全性更新前，定期於每月底評估、測試與更新。 2. 漏洞修復時會先於測試環境套用更新並驗證。	系統更新紀錄			
	資訊系統 監控	74	普	發現資通系統有被入侵跡象時，應通報機關特定人員。	符合	戰情室監控人員依「ISMS_PRC_010 系統監	系統監看程序			

構面	類別	項次編號 (原始)	最低系 統等級 要求	控制措施	是否符合	現況說明	佐證	矯正作為	目標日期	備註說明
						看程序」進行系統異常事件通報。				
	軟體及資 訊完整性	77	普	使用者輸入資料合法性檢查應置放於應用系統伺服器端。	符合	於 ASP.NET 啟用 ValidateRequest 檢查機制。	伺服器組態設定檔案			

資通系統防護基準檢核表(中級系統適用)

資通系統名稱	
機關單位名稱	
填寫人員	
填寫日期	
審核人員	

構面	類別	項次編號 (原始)	最低系 統等級 要求	控制措施	是否符合	現況說明	佐證	矯正作為	目標日期	備註說明
存取控制	帳號管理	1	普	建立帳號管理機制，包含帳號之申請、建立、修改、啟用、停用及刪除之程序。	符合	依「ISMS_WI_016 網站管理辦法」之規範，網站管理帳號變更/新增之申請，需填寫「流程服務管理系統」之「系統帳號/權限異動申請表」，由網站管理者進行變更/新增作業。	1.系統帳號/權限異動申請表 2.帳號權限審核紀錄			
		2	普	已逾期之臨時或緊急帳號應刪除或禁用。	符合	1.臨時帳號建立時由系統設定帳號使用截止日期，逾期自動禁用。 2.每季進行系統帳號權限審查。	1.系統功能規格書/測試記錄 2.帳號權限審核紀錄			
		3	普	資通系統閒置帳號應禁用。	符合	1.系統實作每日檢查排程，自動禁用逾 180 天未登入之帳號。 2.每季進行系統帳號權限審查。	1.系統功能規格書/測試記錄 2.帳號權限審核紀錄			
		4	普	定期審核資通系統帳號之申請、建立、修改、啟用、停用及刪除。	符合	每季進行帳號權限審查。	帳號權限審核紀錄			
		5	中	機關應定義各系統之閒置時間或可使用期限與資通系統之使用情況及條件。	符合	系統設定操作閒置時間 20 分鐘自動登出，無限制使用時段。	伺服器組態設定			
		6	中	逾越機關所許可之閒置時間或可使用期限時，系統應自動將使用者登出。	符合	系統設定操作閒置時間 20 分鐘自動登出。	伺服器組態設定			
	最小權限		普	採最小權限原則，僅允許使用者（或代表使用者行為之程序）依機關任務及業務功能，完成指派任務所需之授權存取。	符合	由網站管理者依「流程服務管理系統」之「系統帳號/權限異動申請表」內容進行作業，設定申請核可之權限。	系統帳號/權限異動申請表			
	遠端存取	10	普	對於每一種允許之遠端存取類型，均應先取得授權，建立使	符合	本系統僅限以內部網路特定 IP 白名單連線至系統	1.系統管理維護手冊 2.系統本機防火牆設定			

構面	類別	項次編號 (原始)	最低系 統等級 要求	控制措施	是否符合	現況說明	佐證	矯正作為	目標日期	備註說明
				用限制、組態需求、連線需求及文件化。		管理後臺，並禁止使用VPN 連線。				
		11	普	使用者之權限檢查作業應於伺服器端完成。	符合	於伺服器端實作 RBAC 集中授權機制。	系統功能規格書			
		12	普	應監控遠端存取機關內部網段或資通系統後臺之連線。	符合	戰情室監控人員依「ISMS_PRC_010 系統監看程序」進行系統異常事件通報。	系統監看程序			
		13	普	應採用加密機制。	符合	已全站台啟用 HTTPS。	系統連線畫面			
		14	普	遠端存取之來源應為機關已預先定義及管理之存取控制點。	符合	本系統僅限以內部網路特定 IP 白名單連線至系統管理後臺，並禁止使用 VPN 連線。	1. 系統管理維護手冊 2. 系統本機防火牆設定			
事件日誌與可歸責性	記錄事件	15	普	訂定日誌之記錄時間週期及留存政策，並保留日誌至少六個月。	符合	資通系統日誌檔案留存於資料庫及日誌伺服器，依中心資安規範至少會保留 6 個月，惟系統未限制日誌留存期限，除非由管理者手動刪除否則會長期留存。	資通系統日誌			
		16	普	確保資通系統有記錄特定事件之功能，並決定應記錄之特定資通系統事件。	符合	資通系統日誌紀錄包含帳號登入成功、登入失敗、帳戶鎖定、系統異常以及管理者執行動作等特定事件。	1. 系統功能規格書 2. 資通系統日誌			
		17	普	應記錄資通系統管理者帳號所執行之各項功能。	符合	資通系統日誌紀錄包含管理者執行動作。	1. 系統功能規格書 2. 資通系統日誌			
		18	中	應定期審查機關所保留資通系統產生之日誌。	符合	使用日誌管理工具收容本系統產生之作業系統及資通系統日誌，每月製成日誌報表，檢視其中異常事件。	資通系統日誌每月報表			

構面	類別	項次編號 (原始)	最低系 統等級 要求	控制措施	是否符合	現況說明	佐證	矯正作為	目標日期	備註說明
	日誌紀錄 內容	19	普	資通系統產生之日誌應包含事件類型、發生時間、發生位置及任何與事件相關之使用者身分識別等資訊，採用單一日誌機制，確保輸出格式之一致性，並應依資通安全政策及法規要求納入其他相關資訊。	符合	1. 資通系統日誌以人事時地物描述特定事件。 2. 統一使用 NLog 日誌記錄框架確保格式一致性。 3. 已於日誌內留存所有必要資訊。	1. 系統功能規格書 2. 資通系統日誌			
	日誌儲存 容量	20	普	依據日誌儲存需求，配置所需之儲存容量。	符合	日誌檔案儲存於資料庫，資料庫已設定容量警示以進行擴充。	資料庫容量警示規則			
	日誌處理 失效之回 應	21	普	資通系統於日誌處理失效時，應採取適當之行動。	符合	系統已實作例外處理機制，當日誌處理失效時自動寄發警示 Email。	Email 警示信件			
	時戳及校 時	23	普	資通系統應使用系統內部時鐘產生日誌所需時戳，並可以對應到世界協調時間(UTC)或格林威治標準時間(GMT)。	符合	日誌時戳已使用作業系統時間，並以慣用時間日期格式呈現。	資通系統日誌檔案			
		24	普	系統內部時鐘應定期與基準時間源進行同步。	符合	與中心自建之 NTP Server(IP:10.20.30.40)進行同步。	NTP 同步測試			
	日誌資訊 之保護	25	普	對日誌之存取管理，僅限於有權限之使用者。	符合	系統日誌檔案僅限資料庫管理者及日誌伺服器管理者存取。	資料庫登入權限、日誌伺服器登入權限			
		26	中	應運用雜湊或其他適當方式之完整性確保機制。	符合	以日誌伺服器收容系統日誌，內建雜湊技術之完整性確保機制。	日誌伺服器功能簡介			
	營運持 續計畫	28	普	訂定資料可容忍損失之時間要求。	符合	本系統 RPO 訂定為 4 小時。	1. 系統風險評鑑表 2. 資訊資產清冊			
		29	普	執行資料備份。	符合	系統資料依規定保管存放於中心建構管理區。	建構管理區			
		30	中	應定期測試備份資料，以驗證備份媒體之可靠性及資訊之完整性。	符合	依中心「ISMS_WI_011 備份與回復規範」進行備份測試。	備份與回復規範			

構面	類別	項次編號 (原始)	最低系 統等級 要求	控制措施	是否符合	現況說明	佐證	矯正作為	目標日期	備註說明
	系統備援	33	普	訂定資通系統從中斷後至重新恢復服務之最大可容忍中斷時間要求。	符合	本系統 RTO 訂定為 4 小時。	1. 系統風險評鑑表 2. 資訊資產清冊			
		34	中	應定期測試原服務中斷時，於最大可容忍中斷時間內，由備援設備或其他方式取代並提供服務。	符合	本系統以虛擬化主機建置，利用快照還原功能恢復主機服務。	備份與回復規範			
識別與鑑別	使用者之識別與鑑別	36	普	資通系統應識別及鑑別使用者，並禁止使用者使用共用帳號。	符合	為後臺管理者帳號開立具管理權限之個人帳號，停用 Administrator 帳號，並禁止共用帳號。	系統特權帳號審查紀錄			
	身分驗證管理	38	普	使用預設密碼初次登入系統時，應於登入後立即變更。	符合	密碼皆為自行設定，未使用預設密碼。	系統功能規格書			
		39	普	身分驗證相關資訊不以明文傳輸。	符合	全站台啟用 HTTPS。	系統連線畫面			
		40	普	具備帳戶鎖定機制，帳號登入進行身分驗證失敗達五次後，至少十五分鐘內不允許該帳號繼續嘗試登入或使用機關自建之失敗驗證機制。	符合	本系統以自然人憑證登入，具帳戶鎖定機制。	自然人憑證鎖定			
		41	普	使用密碼進行驗證時，應強制最低密碼複雜度；依機關密碼效期規定變更密碼。	不適用	本系統以自然人憑證登入，站台無法強制密碼複雜度及效期，故不適用。	系統登入頁面			
		42	普	密碼變更時，至少不可以與前三次使用過之密碼相同。	不適用	本系統以自然人憑證登入，站台不提供自然人密碼變更功能，故不適用。	系統登入頁面			
		43	普	第四點及第五點所定措施，對外部使用者，機關得自行規範辦理。	符合	本系統內部站台，僅限機關內部使用者存取。	系統登入頁面			
		44	中	身分驗證機制應防範自動化程式之登入或密碼更換嘗試。	符合	本系統以自然人憑證登入，具帳戶鎖定機制，可降低密碼破解風險。	自然人憑證鎖定			

構面	類別	項次編號 (原始)	最低系 統等級 要求	控制措施	是否符合	現況說明	佐證	矯正作為	目標日期	備註說明
	鑑別資訊 保護	45	中	密碼重設機制對使用者重新身分確認後，發送一次性及具有時效性符記。	不適用	本系統以自然人憑證登入，站台無法進行密碼重設，故不適用。	自然人憑證密碼重設			
		46	普	資通系統應遮蔽鑑別過程中之資訊。	符合	本系統以自然人憑證登入，系統以星號遮蔽密碼字元。	密碼登入頁面截圖			
		47	中	資通系統如以密碼進行鑑別時，該密碼應經雜湊或其他適當方式處理後儲存。	符合	密碼使用 SHA256 雜湊計算後儲存於資料庫。	資料庫密碼欄位			
系統與 服務獲得	系統發展 生命週期 需求階段	48	普	針對系統安全需求(含機密性、可用性、完整性)進行確認。	符合	本系統 RFP 已具體描述系統安全需求，並確認符合資通系統防護基準之規範。	系統 RFP			
	系統發展 生命週期 設計階段	49	中	根據系統功能與要求，識別可能影響系統之威脅，進行風險分析及評估。	符合	依中心「ISMS_WI_015」系統發展維護辦法，進行威脅建模活動，並使用 Microsoft Threat Modeling Tool 繪製資料流程圖(DFD)後，產出威脅風險評估報告。	Microsoft Threat Modeling Tool Report			
		50	中	將風險評估結果回饋需求階段之檢核項目，並提出安全需求修正。	符合	已依據威脅建模結果重新檢核與強化安全性需求項目，更新於系統 RFP。	1.Microsoft Threat Modeling Tool Report 2.系統 RFP			
	系統發展 生命週期 開發階段	51	普	應針對安全需求實作必要控制措施。	符合	本系統 RFP 已具體描述系統安全需求，並要求開發人員確實實作相關功能	1.系統 RFP 2.系統功能規格書			
		52	普	應注意避免軟體常見漏洞及實作必要控制措施。	符合	已要求開發人員注意安全程式撰寫原則，避免 OWASP Top 10 等常見網站弱點，並配合弱點掃描	1.系統 RFP 2.系統功能規格書 3.弱點掃描報告 4.源碼檢測報告			

構面	類別	項次編號 (原始)	最低系 統等級 要求	控制措施	是否符合	現況說明	佐證	矯正作為	目標日期	備註說明
						與源碼檢測活動，檢測是否存在安全漏洞。				
		53	普	發生錯誤時，使用者頁面僅顯示簡短錯誤訊息及代碼，不包含詳細的錯誤訊息。	符合	使用客製化頁面，僅顯示錯誤代碼及系統負責人員聯絡方式。	系統錯誤頁面			
	系統發展 生命週期 測試階段	56	普	執行「弱點掃描」安全檢測。	符合	已於系統上線前完成弱點掃描，每季依規定進行弱點掃描，並保存弱掃報告及修補紀錄。	弱點掃描報告、弱點掃描修補紀錄			
	系統發展 生命週期 部署與維 運階段	58	普	於部署環境中應針對相關資通安全威脅，進行更新與修補。	符合	1. 進行作業系統之安全性更新前，定期於每月底評估、測試與更新。 2. 每季以 NuGet 套件更新機制更新函式庫版本。	1. 每季系統元件更新紀錄 2. Nmap Port Scan 畫面截圖			
		59	普	識別並關閉不必要服務及埠口。	符合	僅開放 80、443 及 3389。				
		60	普	資通系統不使用預設密碼。	符合	IIS 伺服器、SQL Server 資料庫等皆未使用預設密碼。	現使用之 IIS 及 SQL Server 版本皆未內建預設密碼			
		61	普	執行系統源碼備份。	符合	系統源碼依規定保管存放於中心建構管理區。	建構管理區			
		62	中	於系統發展生命週期之維運階段，應執行版本控制與變更管理。	符合	使用 GIT 進程式版本控制，並依中心變更管理流程填寫「應用系統變更單」。	應用系統變更單			
	系統發展 生命週期 委外階段	63	普	資通系統開發如委外辦理，應將系統發展生命週期各階段依等級將安全需求（含機密性、	不適用	系統為自行開發，未委外辦理。	系統建置計劃書			

構面	類別	項次編號 (原始)	最低系 統等級 要求	控制措施	是否符合	現況說明	佐證	矯正作為	目標日期	備註說明
				可用性、完整性) 納入委外契約。						
	獲得程序	64	普	識別資通系統使用之第三方軟體、服務、函式庫或其他元件。	符合	系統所使用第三方元件已造冊列管。	第三方元件清單			
		65	中	開發、測試以及正式作業環境應為區隔。	符合	開發網段位為 10.20.1.* 測試網段位為 10.20.2.* 正式作業網段位為 10.20.3.*	各作業環境網路規劃			
	系統文件	66	普	應儲存與管理系統發展生命週期之相關文件。	符合	系統文件皆依規定保管存放於中心建構管理區。	建構管理區			
系統與 資訊完 整性	漏洞修復	72	普	系統之漏洞修復應測試有效性及潛在影響，並定期更新。	符合	1. 進行作業系統之安全性更新前，定期於每月底評估、測試與更新。 2. 漏洞修復時會先於測試環境套用更新並驗證。	系統更新紀錄			
		73	中	定期確認資通系統相關漏洞修復之狀態。	符合	每季執行弱點掃描並追蹤呈報修補進度。	弱點修補紀錄			
	資訊系統 監控	74	普	發現資通系統有被入侵跡象時，應通報機關特定人員。	符合	戰情室監控人員依「ISMS_PRC_010 系統監看程序」進行系統異常事件通報。	系統監看程序			
		75	中	監控資通系統，以偵測攻擊與未授權之連線，並識別資通系統之未授權使用。	符合	戰情室監控人員依「ISMS_PRC_010 系統監看程序」進行系統異常事件通報。	系統監看程序			
	軟體及資 訊完整性	77	普	使用者輸入資料合法性檢查應置放於應用系統伺服器端。	符合	於 ASP.NET 啟用 ValidateRequest 檢查機制。	伺服器組態設定檔案			

構面	類別	項次編號 (原始)	最低系 統等級 要求	控制措施	是否符合	現況說明	佐證	矯正作為	目標日期	備註說明
		78	中	使用完整性驗證工具，以偵測未授權變更特定軟體及資訊。	符合	使用目錄監控軟體，監視站台目錄。	目錄監控軟體			
		79	中	發現違反完整性時，資通系統應實施機關指定之安全保護措施。	符合	戰情室監控人員依「ISMS_PRC_010 系統監看程序」進行系統異常事件通報，承辦人員依資通安全事件通報及應變辦法之規定進行通報。	1. 系統監看程序 2. 事件通報紀錄			

資通系統防護基準檢核表(高級系統適用)

資通系統名稱	
機關單位名稱	
填寫人員	
填寫日期	
審核人員	

構面	類別	項次編號 (原始)	最低系 統等級 要求	控制措施	是否符合	現況說明	佐證	矯正作為	目標日期	備註說明
存取控制	帳號管理	1	普	建立帳號管理機制，包含帳號之申請、建立、修改、啟用、停用及刪除之程序。	符合	依「ISMS_WI_016 網站管理辦法」之規範，網站管理帳號變更/新增之申請，需填寫「流程服務管理系統」之「系統帳號/權限異動申請表」，由網站管理者進行變更/新增作業。	1.系統帳號/權限異動申請表 2.帳號權限審核紀錄			
		2	普	已逾期之臨時或緊急帳號應刪除或禁用。	符合	1.臨時帳號建立時由系統設定帳號使用截止日期，逾期自動禁用。 2.每季進行系統帳號權限審查。	1.系統功能規格書/測試記錄 2.帳號權限審核紀錄			
		3	普	資通系統閒置帳號應禁用。	符合	1.系統實作每日檢查排程，自動禁用逾 180 天未登入之帳號。 2.每季進行系統帳號權限審查。	1.系統功能規格書/測試記錄 2.帳號權限審核紀錄			
		4	普	定期審核資通系統帳號之申請、建立、修改、啟用、停用及刪除。	符合	每季進行帳號權限審查。	帳號權限審核紀錄			
		5	中	機關應定義各系統之閒置時間或可使用期限與資通系統之使用情況及條件。	符合	系統設定操作閒置時間 20 分鐘自動登出，無限制使用時段。	伺服器組態設定			
		6	中	逾越機關所許可之閒置時間或可使用期限時，系統應自動將使用者登出。	符合	系統設定操作閒置時間 20 分鐘自動登出。	伺服器組態設定			
		7	高	應依機關規定之情況及條件，使用資通系統。	符合	資通系統僅限使用自然人憑證登入。	系統使用手冊			
		8	高	監控資通系統帳號，如發現帳號違常使用時回報管理者。	符合	部署 WAF 防護設備，偵測及阻擋站台惡意使用行為。	WAF 組態設定			
	最小權限	9	普	採最小權限原則，僅允許使用者（或代表使用者行為之程序）依機關任務及業務功能，	符合	由網站管理者依「流程服務管理系統」之	系統帳號/權限異動申請表			

構面	類別	項次編號 (原始)	最低系 統等級 要求	控制措施	是否符合	現況說明	佐證	矯正作為	目標日期	備註說明
	遠端存取			完成指派任務所需之授權存取。		「系統帳號/權限異動申請表」內容進行作業，設定申請核可之權限。				
		10	普	對於每一種允許之遠端存取類型，均應先取得授權，建立使用限制、組態需求、連線需求及文件化。	符合	本系統僅限以內部網路特定 IP 白名單連線至系統管理後臺，並禁止使用 VPN 連線。	1. 系統管理維護手冊 2. 系統本機防火牆設定			
		11	普	使用者之權限檢查作業應於伺服器端完成。	符合	於伺服器端實作 RBAC 集中授權機制。	系統功能規格書			
		12	普	應監控遠端存取機關內部網段或資通系統後臺之連線。	符合	戰情室監控人員依「ISMS_PRC_010 系統監看程序」進行系統異常事件通報。	系統監看程序			
		13	普	應採用加密機制。	符合	已全站台啟用 HTTPS。	系統連線畫面			
		14	普	遠端存取之來源應為機關已預先定義及管理之存取控制點。	符合	本系統僅限以內部網路特定 IP 白名單連線至系統管理後臺，並禁止使用 VPN 連線。	1. 系統管理維護手冊 2. 系統本機防火牆設定			
事件日誌與可歸責性	記錄事件	15	普	訂定日誌之記錄時間週期及留存政策，並保留日誌至少六個月。	符合	資通系統日誌檔案留存於資料庫及日誌伺服器，依中心資安規範至少會保留 6 個月，惟系統未限制日誌留存期限，除非由管理者手動刪除否則會長期留存。	資通系統日誌			
		16	普	確保資通系統有記錄特定事件之功能，並決定應記錄之特定資通系統事件。	符合	資通系統日誌紀錄包含帳號登入成功、登入失敗、帳戶鎖定、系統異常以及管理者執行動作等特定事件。	1. 系統功能規格書 2. 資通系統日誌			
		17	普	應記錄資通系統管理者帳號所執行之各項功能。	符合	資通系統日誌紀錄包含管理者執行動作。	1. 系統功能規格書 2. 資通系統日誌			
		18	中	應定期審查機關所保留資通系統產生之日誌。	符合	使用日誌管理工具收容本系統產生之作業系統及資	資通系統日誌每月報表			

構面	類別	項次編號 (原始)	最低系 統等級 要求	控制措施	是否符合	現況說明	佐證	矯正作為	目標日期	備註說明
						通系統日誌，每月製成日誌報表，檢視其中異常事件。				
	日誌紀錄 內容	19	普	資通系統產生之日誌應包含事件類型、發生時間、發生位置及任何與事件相關之使用者身分識別等資訊，採用單一日誌機制，確保輸出格式之一致性，並應依資通安全政策及法規要求納入其他相關資訊。	符合	1. 資通系統日誌以人事時地物描述特定事件。 2. 統一使用 NLog 日誌記錄框架確保格式一致性。 3. 已於日誌內留存所有必要資訊。	1. 系統功能規格書 2. 資通系統日誌			
	日誌儲存 容量	20	普	依據日誌儲存需求，配置所需之儲存容量。	符合	日誌檔案儲存於資料庫，資料庫已設定容量警示以進行擴充。	資料庫容量警示規則			
	日誌處理 失效之回 應	21	普	資通系統於日誌處理失效時，應採取適當之行動。	符合	系統已實作例外處理機制，當日誌處理失效時自動寄發警示 Email。	Email 警示信件			
		22	高	機關規定需要即時通報之日誌處理失效事件發生時，資通系統應於機關規定之時效內，對特定人員提出警告。	符合	系統已實作例外處理機制，當日誌處理失效時自動寄發警示 Email。	Email 警示信件			
	時戳及校 時	23	普	資通系統應使用系統內部時鐘產生日誌所需時戳，並可以對應到世界協調時間(UTC)或格林威治標準時間(GMT)。	符合	日誌時戳已使用作業系統時間，並以慣用時間日期格式呈現。	資通系統日誌檔案			
		24	普	系統內部時鐘應定期與基準時間源進行同步。	符合	與中心自建之 NTP Server(IP:10.20.30.40)進行同步。	NTP 同步測試			
	日誌資訊 之保護	25	普	對日誌之存取管理，僅限於有權限之使用者。	符合	系統日誌檔案僅限資料庫管理者及日誌伺服器管理者存取。	資料庫登入權限、日誌伺服器登入權限			
		26	中	應運用雜湊或其他適當方式之完整性確保機制。	符合	以日誌伺服器收容系統日誌，內建雜湊技術之完整性確保機制。	日誌伺服器功能簡介			

構面	類別	項次編號 (原始)	最低系 統等級 要求	控制措施	是否符合	現況說明	佐證	矯正作為	目標日期	備註說明
		27	高	定期備份日誌至原系統外之其他實體系統。	符合	每週備份資料庫虛擬化主機。	ISMS_WI_011 備份與回復規範			
營運持續計畫	資料備份	28	普	訂定資料可容忍損失之時間要求。	符合	本系統 RPO 訂定為 4 小時。	1. 系統風險評鑑表 2. 資訊資產清冊			
		29	普	執行資料備份。	符合	系統資料依規定保管存放於中心建構管理區。	建構管理區			
		30	中	應定期測試備份資料，以驗證備份媒體之可靠性及資訊之完整性。	符合	依中心「ISMS_WI_011 備份與回復規範」進行備份測試。	備份與回復規範			
		31	高	應將備份還原，作為營運持續計畫演練之一部分。	符合	已執行 BCP 演練，含備份還原測試。最近一次執行日期為 110 年 6 月 1 日。	營運持續計畫演練報告			
		32	高	應建立資料異地備份機制。	符合	依中心「ISMS_WI_011 備份與回復規範」進行異地備份至南部辦公室。	ISMS_WI_011 備份與回復規範			
	系統備援	33	普	訂定資通系統從中斷後至重新恢復服務之最大可容忍中斷時間要求。	符合	本系統 RTO 訂定為 4 小時。	1. 系統風險評鑑表 2. 資訊資產清冊			
		34	中	應定期測試原服務中斷時，於最大可容忍中斷時間內，由備援設備或其他方式取代並提供服務。	符合	本系統以虛擬化主機建置，利用快照還原功能恢復主機服務。	備份與回復規範			
		35	高	應將備援啟動作為營運持續計畫演練之一部分。	符合	已執行 BCP 演練，含備份還原測試。最近一次執行日期為 110 年 6 月 1 日	營運持續計畫測試報告			
識別與鑑別	使用者之識別與鑑別	36	普	資通系統應識別及鑑別使用者，並禁止使用者使用共用帳號。	符合	為後臺管理者帳號開立具管理權限之個人帳號，停用 Administrator 帳號，並禁止共用帳號。	系統特權帳號審查紀錄			
		37	高	對資通系統之存取採取多因子鑑別技術。	符合	使用自然人憑證登入，符合使用「所知之事」及「所持之物」兩種身分驗證因子。	系統登入畫面			

構面	類別	項次編號 (原始)	最低系 統等級 要求	控制措施	是否符合	現況說明	佐證	矯正作為	目標日期	備註說明
	身分驗證 管理	38	普	使用預設密碼初次登入系統時，應於登入後立即變更。	符合	密碼皆為自行設定，未使用預設密碼。	系統功能規格書			
		39	普	身分驗證相關資訊不以明文傳輸。	符合	全站台啟用 HTTPS。	系統連線畫面			
		40	普	具備帳戶鎖定機制，帳號登入進行身分驗證失敗達五次後，至少十五分鐘內不允許該帳號繼續嘗試登入或使用機關自建之失敗驗證機制。	符合	本系統以自然人憑證登入，具帳戶鎖定機制。	自然人憑證鎖定			
		41	普	使用密碼進行驗證時，應強制最低密碼複雜度；依機關密碼效期規定變更密碼。	不適用	本系統以自然人憑證登入，站台無法強制密碼複雜度及效期，故不適用。	系統登入頁面			
		42	普	密碼變更時，至少不可以與前三次使用過之密碼相同。	不適用	本系統以自然人憑證登入，站台不提供自然人密碼變更功能，故不適用。	系統登入頁面			
		43	普	第四點及第五點所定措施，對外部使用者，機關得自行規範辦理。	符合	本系統內部站台，僅限機關內部使用者存取。	系統登入頁面			
		44	中	身分驗證機制應防範自動化程式之登入或密碼更換嘗試。	符合	本系統以自然人憑證登入，具帳戶鎖定機制，可降低密碼破解風險。	自然人憑證鎖定			
		45	中	密碼重設機制對使用者重新身分確認後，發送一次性及具有時效性符記。	不適用	本系統以自然人憑證登入，站台無法進行密碼重設，故不適用。	自然人憑證密碼重設			
	鑑別資訊 保護	46	普	資通系統應遮蔽鑑別過程中之資訊。	符合	本系統以自然人憑證登入，系統以星號遮蔽密碼字元。	密碼登入頁面截圖			
		47	中	資通系統如以密碼進行鑑別時，該密碼應經雜湊或其他適當方式處理後儲存。	符合	密碼使用 SHA256 雜湊計算後儲存於資料庫。	資料庫密碼欄位			

構面	類別	項次編號 (原始)	最低系 統等級 要求	控制措施	是否符合	現況說明	佐證	矯正作為	目標日期	備註說明
系統與 服務獲 得	系統發展 生命週期 需求階段	48	普	針對系統安全需求(含機密性、可用性、完整性)進行確認。	符合	本系統 RFP 已具體描述系統安全需求，並確認符合資通系統防護基準之規範。	系統 RFP			
	系統發展 生命週期 設計階段	49	中	根據系統功能與要求，識別可能影響系統之威脅，進行風險分析及評估。	符合	依中心「ISMS_WI_015」系統發展維護辦法，進行威脅建模活動，並使用 Microsoft Threat Modeling Tool 繪製資料流程圖(DFD)後，產出威脅風險評估報告。	Microsoft Threat Modeling Tool Report			
		50	中	將風險評估結果回饋需求階段之檢核項目，並提出安全需求修正。	符合	已依據威脅建模結果重新檢核與強化安全性需求項目，更新於系統 RFP。	1.Microsoft Threat Modeling Tool Report 2. 系統 RFP			
	系統發展 生命週期 開發階段	51	普	應針對安全需求實作必要控制措施。	符合	本系統 RFP 已具體描述系統安全需求，並要求開發人員確實實作相關功能	1. 系統 RFP 2. 系統功能規格書			
		52	普	應注意避免軟體常見漏洞及實作必要控制措施。	符合	已要求開發人員注意安全程式撰寫原則，避免 OWASP Top 10 等常見網站弱點，並配合弱點掃描與源碼檢測活動，檢測是否存在安全漏洞。	1. 系統 RFP 2. 系統功能規格書 3. 弱點掃描報告 4. 源碼檢測報告			
		53	普	發生錯誤時，使用者頁面僅顯示簡短錯誤訊息及代碼，不包含詳細的錯誤訊息。	符合	使用客製化頁面，僅顯示錯誤代碼及系統負責人員聯絡方式。	系統錯誤頁面			
		54	高	執行「源碼掃描」安全檢測。	符合	使用中心自購之源碼掃描工具，於程式碼變更時執行檢測。	源碼掃描報告、源碼掃描修補紀錄			
		55	高	系統應具備發生嚴重錯誤時之通知機制。	符合	系統實作例外處理機制，自動發送警示信件。	錯誤警示信件			

構面	類別	項次編號 (原始)	最低系 統等級 要求	控制措施	是否符合	現況說明	佐證	矯正作為	目標日期	備註說明
	系統發展 生命週期 測試階段	56	普	執行「弱點掃描」安全檢測。	符合	已於系統上線前完成弱點掃描，每季依規定進行弱點掃描，並保存弱掃報告及修補紀錄。	弱點掃描報告、弱點掃描修補紀錄			
		57	高	執行「滲透測試」安全檢測。	符合	已於系統上線前完成滲透測試，每季依規定進行滲透測試，並保存滲透測試報告及修補紀錄。	滲透測試報告、滲透測試修補紀錄			
	系統發展 生命週期 部署與維 運階段	58	普	於部署環境中應針對相關資通安全威脅，進行更新與修補。	符合	1. 進行作業系統之安全性更新前，定期於每月底評估、測試與更新。 2. 每季以 NuGet 套件更新機制更新函式庫版本。	每季系統元件更新紀錄			
		59	普	識別並關閉不必要服務及埠口。	符合	僅開放 80、443 及 3389。	Nmap Port Scan 畫面截圖			
		60	普	資通系統不使用預設密碼。	符合	IIS 伺服器、SQL Server 資料庫等皆未使用預設密碼。	現使用之 IIS 及 SQL Server 版本皆未內建預設密碼			
		61	普	執行系統源碼備份。	符合	系統源碼依規定保管存放於中心建構管理區。	建構管理區			
		62	中	於系統發展生命週期之維運階段，應執行版本控制與變更管理。	符合	使用 GIT 進程式版本控制，並依中心變更管理流程填寫「應用系統變更單」。	應用系統變更單			
	系統發展 生命週期 委外階段	63	普	資通系統開發如委外辦理，應將系統發展生命週期各階段依等級將安全需求（含機密性、可用性、完整性）納入委外契約。	不適用	系統為自行開發，未委外辦理。	系統建置計劃書			

構面	類別	項次編號 (原始)	最低系 統等級 要求	控制措施	是否符合	現況說明	佐證	矯正作為	目標日期	備註說明
	獲得程序	64	普	識別資通系統使用之第三方軟體、服務、函式庫或其他元件。	符合	系統所使用第三方元件已造冊列管。	第三方元件清單			
		65	中	開發、測試以及正式作業環境應為區隔。	符合	開發網段位為 10.20.1.* 測試網段位為 10.20.2.* 正式作業網段位為 10.20.3.*	各作業環境網路規劃			
	系統文件	66	普	應儲存與管理系統發展生命週期之相關文件。	符合	系統文件皆依規定保管存放於中心建構管理區。	建構管理區			
系統與 通訊保 護	傳輸之機 密性與完 整性	67	高	資通系統應採用加密機制，以防止未授權之資訊揭露或偵測資訊之變更。但傳輸過程中有替代之實體保護措施者，不在此限。	符合	全系統啟用 HTTPS。	站台連線畫面			
		68	高	使用公開、國際機構驗證且未遭破解的演算法。	未符合	系統 HTTPS 未停用 TLS1.1 傳輸協定。	nmap 檢測畫面	停用 TLS1.1， 僅允許使用 TLS1.2 以上版本	110 年 10 月 1 日	
		69	高	加密金鑰或憑證週期性更換。	符合	使用效期內之 HTTPS 加密憑證，依規定每年更新。	站台加密憑證			
		70	高	伺服器端之金鑰保管應製定管理規則及實施應有之安全防護措施。	符合	將加密金鑰與加密資料分開存放，僅允許系統管理者存取加密金鑰。	伺服器金鑰管理規則			
	資料儲存 之安全	71	高	資通系統重要組態設定檔案及其他具保護需求之資訊應加密或以其他適當方式儲存。	符合	加密資料庫連線字串。	伺服器組態設定檔			
系統與 資訊完 整性	漏洞修復	72	普	系統之漏洞修復應測試有效性及潛在影響，並定期更新。	符合	1. 進行作業系統之安全性更新前，定期於每月底評估、測試與更新。 2. 漏洞修復時會先於測試環境套用更新並驗證。	系統更新紀錄			

構面	類別	項次編號 (原始)	最低系 統等級 要求	控制措施	是否符合	現況說明	佐證	矯正作為	目標日期	備註說明
	資訊系統 監控	73	中	定期確認資通系統相關漏洞修復之狀態。	符合	每季執行弱點掃描並追蹤呈報修補進度。	弱點修補紀錄			
		74	普	發現資通系統有被入侵跡象時，應通報機關特定人員。	符合	戰情室監控人員依「ISMS_PRC_010 系統監看程序」進行系統異常事件通報。	系統監看程序			
		75	中	監控資通系統，以偵測攻擊與未授權之連線，並識別資通系統之未授權使用。	符合	戰情室監控人員依「ISMS_PRC_010 系統監看程序」進行系統異常事件通報。	系統監看程序			
		76	高	資通系統應採用自動化工具監控進出之通信流量，並於發現不尋常或未授權之活動時，針對該事件進行分析。	符合	部署 WAF 防護設備，偵測及阻擋站台惡意使用行為。	WAF 組態設定			
	軟體及資 訊完整性	77	普	使用者輸入資料合法性檢查應置放於應用系統伺服器端。	符合	於 ASP.NET 啟用 ValidateRequest 檢查機制。	伺服器組態設定檔案			
		78	中	使用完整性驗證工具，以偵測未授權變更特定軟體及資訊。	符合	使用目錄監控軟體，監視站台目錄。	目錄監控軟體			
		79	中	發現違反完整性時，資通系統應實施機關指定之安全保護措施。	符合	戰情室監控人員依「ISMS_PRC_010 系統監看程序」進行系統異常事件通報，承辦人員依資通安全事件通報及應變辦法之規定進行通報。	1. 系統監看程序 2. 事件通報紀錄			
		80	高	應定期執行軟體和資訊完整性檢查。	符合	每月利用完整性檢查工具，比對網站目錄內容之異動。	網站目錄完整性檢查結果報告			